SEGMENTO PROTECT

DSAR Portal & Consent Hub

System Architecture, Request Lifecycle, Consent Operations and Audit Evidence

PUBLIC PRODUCT DOCUMENTATION
Feature availability, integrations, test results, legal references, and security parameters should be verified for the target deployment before publication.

Executive Summary

The Segmento DSAR Portal & Consent Hub is a privacy-workflow platform designed to coordinate data subject requests across connected operational systems, analytics environments, marketing channels, third-party services, and AI/ML processing workflows.

It separates request intake, identity verification, data discovery, impact assessment, policy review, execution, verification, communications, and evidence generation into a traceable process. The Consent Hub separately supports purpose-specific consent withdrawal without treating it as account deletion.

Implementation status and connector availability can vary by deployment. Feature descriptions in this document should be read alongside the environment's configuration and verified test results.

Purpose and Scope

The portal is intended to help privacy and operations teams register requests, coordinate the teams responsible for affected systems, apply policy-driven actions, track execution status, and retain evidence of the actions taken.

Supported request categories described in the project specification include access, erasure, correction, and consent revocation. Jurisdiction classification and applicable response timelines should be configured for the organisation and the relevant legal regime.

Legal and Governance Context

The supplied design references India's Digital Personal Data Protection Act 2023, the EU General Data Protection Regulation, California CCPA/CPRA, Singapore PDPA, and record-retention requirements that may apply to financial and tax records.

Examples of referenced provisions include DPDP Act Sections 6, 11 and 12; GDPR Articles 5(2), 7(3), 15, 17 and 21; and applicable tax or financial record-retention rules. The exact legal basis, applicability, commencement status, exemptions, and retention period must be confirmed by qualified legal/compliance personnel for each deployment.

The portal should support explainable policy decisions rather than treating a configured rule as a substitute for legal review. Statutory timelines must be configurable; a single fixed countdown should not be assumed to apply to every jurisdiction and request type.

Account Deletion vs Consent Withdrawal

Account deletion and consent withdrawal are separate workflows. An erasure request may lead to deletion or other lawful disposition of eligible personal data, subject to applicable exceptions and retention duties.

Consent withdrawal revokes the relevant consent-based processing permissions. It does not, by itself, require the customer's account to be terminated. The account can remain active while marketing, analytics, third-party sharing, or AI-training permissions are updated according to the user's selection and applicable rules.

Illustrative consent categories in the supplied design are Essential/Functional, Analytics & Performance, Marketing & Promotions, Third-Party Syndication, and AI/ML Model Training. Essential service processing should not be represented as optional consent if it is required for the service or relies on another legal basis.

System Architecture: Six Layers

Layer 1 — User and Interface Operations Hub: self-service intake, privacy mailbox intake, operations dashboard, case detail tabs, consent controls, status visibility, and operational metrics.

Layer 2 — API Gateway and Security: OAuth 2.0/OIDC, RS256-signed JWTs, JWKS publication, token introspection where configured, role/scope enforcement, rate limiting, and correlation IDs for request tracing.

Layer 3 — Orchestration and Privacy Engines: intent and jurisdiction classification; identity discovery; dependency/impact analysis; policy evaluation; dry-run simulation; execution; residual-PII verification; certificate generation; and case timeline/evidence services.

Layer 4 — Persistence and Ledgers: relational request and customer data, legal-hold records, statutory archives, a local evaluation fallback where configured, and consent state records.

Layer 5 — Event Streaming: Apache Kafka topics and consumer integrations used to propagate consent and DSAR events to connected systems. Delivery and final enforcement status should be tracked separately.

Layer 6 — Verification and Regulatory Outputs: completion evidence, integrity checks, certificates, and exportable evidence packages. A hash provides integrity checking; a hash alone does not make storage immutable or constitute a digital signature.

Seven-Stage Privacy Request Lifecycle

Stage 1 — Intake and intent classification: capture the request through the portal, configured API, or email intake; classify the request category and likely jurisdiction; assign a case identifier; and initiate the configured deadline calculation. Identity verification should be proportionate to risk and may require manual review.

Stage 2 — Multi-store discovery: search configured repositories using permitted identifiers such as email, phone number, or a subject identifier. Candidate systems in the supplied design include PostgreSQL, a billing database, Snowflake, CRM, and statutory archives. Produce a normalized inventory with source, schema/table, key, field type, result count, timestamp, and search status.

Stage 3 — Impact analysis: assess foreign-key relationships, dependent records, subscriptions, and downstream effects. Surface risks for human review before destructive operations. Any numerical risk score should be explainable and validated rather than presented as an objective legal conclusion.

Stage 4 — Policy evaluation and dry run: evaluate retention requirements and applicable exceptions. Generate a preview of proposed actions without changing production data. The supplied action categories are HARD_PURGE, PSEUDONYMIZE, STATUTORY_RETAIN, and SUPPRESS. Require the configured DPO or authorised approver sign-off before execution where policy requires it.

Stage 5 — Execution: perform approved transformations through configured connectors. Coordinate database changes and downstream events carefully; use idempotency and recovery controls to avoid duplicate or inconsistent actions.

Stage 6 — Verification: run a secondary scan across the defined and accessible scope. Report which systems were checked, which were inaccessible, and any unresolved findings. A failed or unavailable scan must not be represented as zero residual PII.

Stage 7 — Certificate and notification: generate a case-specific completion record, attach the supported evidence, and notify the requester through the configured delivery channel. The certificate must reflect actual results, retained records, exceptions, and unresolved work.

Case Timeline and Evidence Vault

The supplied design describes a chronological case timeline and a hash-chained evidence record. Suggested milestones include intake, identity verification, discovery, impact analysis, policy evaluation, dry-run simulation, approval, execution, connector reconciliation, verification, and certificate issuance.

A hash-chain entry can be designed to incorporate the previous hash and a canonical representation of timestamp, actor, action, and evidence reference. Canonical serialization, trusted timestamps, access restrictions, key management where signing is used, and protected storage are necessary for a dependable audit design.

Exportable evidence packages may include the case ID, request scope, system search manifest, decisions and their rationale, approvals, execution outcomes, connector statuses, verification results, exceptions, and integrity metadata. Avoid placing unnecessary personal data in evidence exports.

Consent Hub and Event Streaming

The Consent Hub records purpose-level consent states and emits events for downstream enforcement. The supplied design references consent withdrawal and grant topics and a dead-letter queue for failed processing.

Example downstream systems include CRM platforms, marketing delivery tools, analytics/lakehouse systems, AI/ML pipelines, and third-party integrations. Each connector should report event receipt, processing outcome, retries, and target-state reconciliation.

A Kafka acknowledgement confirms broker-level handling according to the configured producer semantics; it does not alone prove that every downstream system has applied the change. Failed events should be retried safely, monitored, and escalated when unresolved.

Departmental Task Delegation and SLA Monitoring

The supplied design identifies teams such as CRM, HR, Marketing, Data Engineering, Vendor Management, and Privacy/Legal. Tasks should have an owner, due date, status, dependency, evidence requirement, and escalation route.

Deadline calculation should be driven by configurable legal rules and recorded inputs. Notifications can alert owners and privacy leadership about approaching deadlines, overdue tasks, blocked work, and requests awaiting review.

Security and API Controls

The design references OAuth 2.0/OIDC, RS256 JWTs, JWKS, scoped authorisation, rate limiting, and correlation IDs. The user interface persona switcher must not grant privileges by itself; permissions must be enforced by the backend against authenticated identities and authorised scopes.

Recommended operational controls include tenant isolation tests, least-privilege service accounts, secrets management, audit logging, input validation, rate-limit tests, and access review. Only expose endpoints and data that are intended for the relevant public or authenticated role.

Testing and Operational Validation

The supplied project notes report 21 test suites and 169 automated tests for the DSAR portal. These figures are project-provided claims and should be published only after the current test run, repository, and environment have been verified.

Validation scenarios should cover successful requests, identity mismatch, partial discovery, legal hold, dry-run rejection, connector failure, retry and replay, duplicate events, incomplete verification, certificate generation, access denial, and tenant isolation.

Operational dashboards should distinguish simulated connectors from live integrations, and distinguish planned functionality from functionality verified in the deployed environment.

Example Walkthrough

Example: a customer requests deletion of a profile and browsing data, while an invoice is subject to a confirmed retention requirement. The portal registers the request, verifies identity, searches connected systems, identifies dependencies, and produces a policy plan.

The authorised reviewer examines the proposed deletion and retention actions. After approval, eligible data is processed, downstream events are sent, and each connector's outcome is tracked. Verification reports the systems actually checked and any exceptions. The final evidence package documents completed actions and any retained records without claiming more than the evidence supports.

Deployment and Website Presentation Notes

For public website publication, describe the system's intended capabilities accurately and identify any deployment-specific or optional integrations. Do not expose secrets, customer data, internal hostnames, private repository paths, or production credentials.

Before publishing legal claims, retention periods, certification statements, test statistics, or claims such as 'zero residual PII', obtain technical and legal review. This document is technical product documentation and is not legal advice.

Document status and review

Prepared from the project-provided technical specification. Confirm current implementation, supported configuration, test results, legal references, and security parameters with the responsible teams before publication.